

Vulnerability Assessment Report

FRAMEWORK

NIST SP 800-30 Rev. 1

PREPARED BY

Joseph Guidici

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of the Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures currently include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment covers a period of three months, from June to August of the current year. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system.

Purpose

The database server is a centralized computer system that stores and manages large amounts of data. The server is used to store customer, campaign, and analytic data that can later be analyzed to track performance and personalize marketing efforts. It is critical to secure the system because of its regular use for core marketing operations.

Risk Assessment

Threat Source	Threat Event	Likelihood (1-3)	Severity (1-3)	Risk Score
Hacker	Obtain sensitive information via exfiltration	3	3	9
Employee	Disrupt mission-critical operations	2	3	6
Customer	Alter / Delete critical information	1	3	3

Risk Key:

High (7-9)

Medium (4-6)

Low (1-3)

Approach

Risks were measured by considering the data storage and management procedures of the business. Potential threat sources and events were determined using the likelihood of a security incident given the open access permissions of the information system. The severity of potential incidents was weighed against the impact on day-to-day operational needs.

Remediation Strategy

- **Authentication & Authorization:** Implement strong passwords, role-based access controls (RBAC), and multi-factor authentication (MFA) to limit user privileges and ensure only authorized users can access the database server.
- **Encryption in Transit:** Migrate from SSL to TLS for all data transmitted to and from the server, ensuring communications cannot be intercepted or tampered with.
- **IP Allow-Listing:** Restrict inbound connections to approved corporate IP ranges, preventing unauthorized internet users from reaching the database server directly.

- **Auditing & Monitoring:** Establish logging and auditing mechanisms to track access events and detect anomalous behavior, enabling rapid incident response.